TECHNICAL DEEP DIVE

SupportPilot AI

How a multi-tenant support assistant answers from each company’s own docs, never shows one customer another’s data, and always has a human one step away.

FastAPI · React · any LLM provider · github.com/akhil4rajan/supportpilot-ai

01 · THE STACK

Four parts, each small enough to read in an afternoon

Embeddable widget

React 19 + TypeScript inside Shadow DOM, so the host site’s CSS can’t break it. One script tag, about 73 KB gzipped.

`frontend/src/widget`

Async API

FastAPI and async SQLAlchemy. SQLite in dev, Postgres in prod. Redis for WebSocket fan-out and shared rate limits across pods.

`backend/app/api`

Agent loop

A provider-agnostic tool-use loop with five tools. Anthropic’s native SDK, or any OpenAI-compatible API: OpenAI, Gemini, Llama, Ollama.

`backend/app/agent`

Ops and quality

Prometheus metrics, health checks, JSON logs. 153 tests, release-gate evals in CI, a load generator and a capacity model.

`backend/evals`

Multi-tenant by configuration. Each company is a folder: tenant.yaml plus a knowledge/ folder. Onboarding needs no code.

What runs today, end to end

CUSTOMER SIDE

Company’s backend
Signs a short-lived user token

Chat widget
REST for turns, WebSocket for live

Agent console
Queue, take over, reply, resolve



SUPPORTPILOT API · FASTAPI, ASYNC

/v1/widget · /v1/agent · /v1/admin REST + WebSocket

Orchestrator tool-use loop, at most 6 model steps

`search_knowledge_base · get_order_status · list_my_orders · create_support_ticket · escalate_to_human`

Tenant runtime KB index, persona, providers, agents

State SQL, Redis pub/sub, ticket outbox, audit log



INTEGRATIONS

LLM provider
any of 12+, with fallback

Order API
scoped to the verified user

Jira
tickets via an outbox

Slack webhook
pings on handoff

From keystroke to reply, in seven steps

1. **Session.** The host’s token is verified once; we mint a widget token bound to tenant and conversation.
2. **Message in.** Rate-limited per conversation, size-capped, saved.
3. **Human owns it?** Then the bot stays silent.
4. **Safety net.** “Get me a human” matches a regex and hands off without asking the model.
5. **Tool loop.** Cacheable prompt + last 30 messages → model → tools → model, at most 6 steps.
6. **Reply out.** Saved with sources and timings; pushed to widget and console over WebSocket.
7. **Miss counter.** Two knowledge-base misses in a row trigger an automatic handoff.

ONE RULE THAT MATTERS

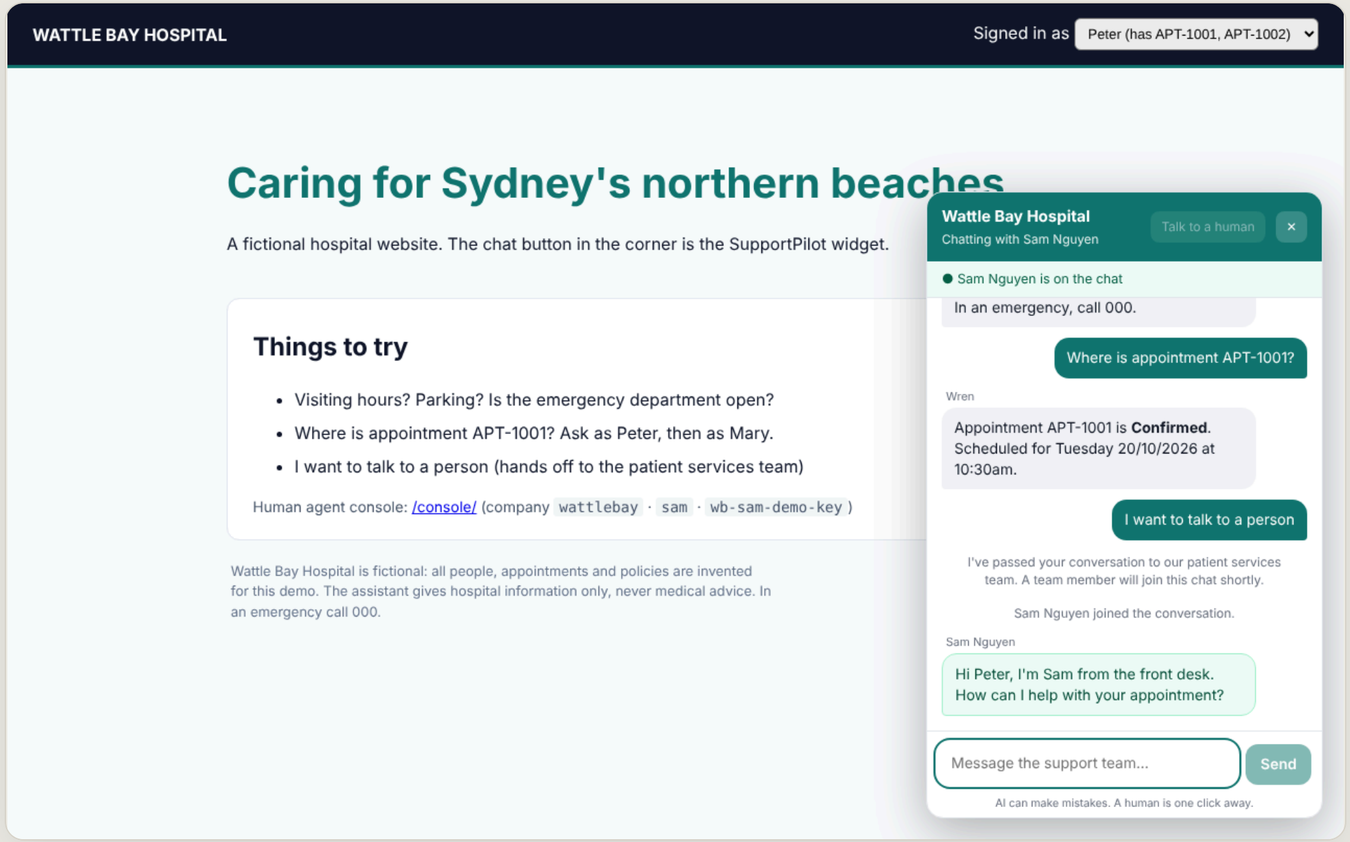
Never hold a database connection while waiting on the model.

```
await db.commit()
resp = await llm.complete(…)
```

A turn spends seconds in the model. Holding a pooled connection that long caps concurrency at the pool size. The load test found this; slide 12 has the story.

04 · LIVE DEMO

The same pipeline, on a fictional Sydney hospital



WHAT I'LL SHOW

1 · Guest: "How much does parking cost?" Answer cites the parking doc.

2 · Peter: "Where is APT-1001?" Confirmed, 20/10/2026, 10:30am.

3 · Mary: same question. "No appointment found."

4 · Peter: "I want to talk to a person." Sam takes over in the console.

Recorded with LLM_PROVIDER=demo, a keyword stand-in model. Auth, KB, lookups and handoff are the real code paths.

05 · GROUNDING

Answer from the docs, or say “I don’t know”

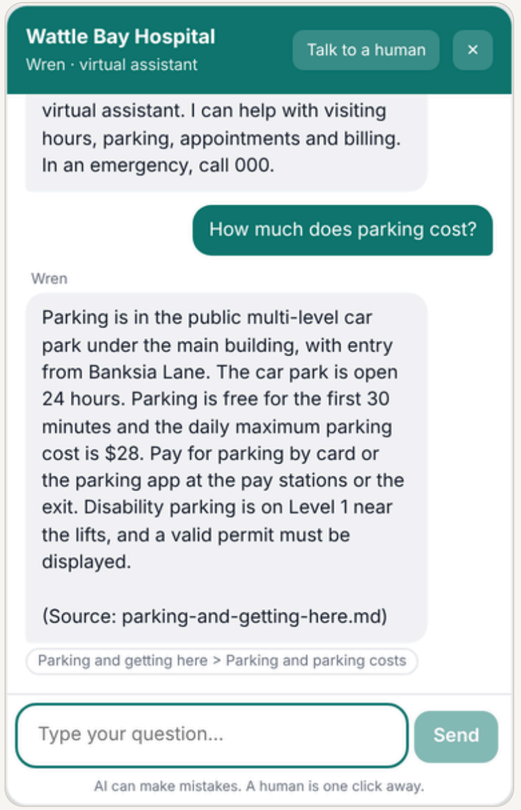
```
Markdown → chunks by heading → BM25 with stemming and per-tenant synonyms →
coverage score
```

Coverage = share of the question’s IDF-weighted terms found in a chunk, on a 0–1 scale.

Band	Coverage	What the model is told
confident	≥ 0.35	Answer from it and cite the source
possible	0.10 – 0.35	Use only if it directly answers
none	< 0.10	Say so; counts as a miss

Why BM25 and not embeddings?

No extra infrastructure, deterministic, explainable, strong on FAQ and policy text. KnowledgeBase.search() is the seam for pgvector or hybrid search when the retrieval gates call for it.



Who’s asking comes from a signature, not the chat

`aud=supportpilot`

User token

Signed by the **company’s** backend with a per-tenant secret. HS256, at most 1 hour. The only source of “who is this user”.

`aud=widget`

Widget token

Minted by SupportPilot after the user token checks out. Binds tenant and conversation for later calls.

`aud=agent`

Agent token

Minted when a human agent signs in with their key (compared in constant time).

Rejected with 401, each covered by a test:

`wrong secret` `wrong audience` `expired` `alg=none` `lifetime over 1 hour` `another tenant’s token`

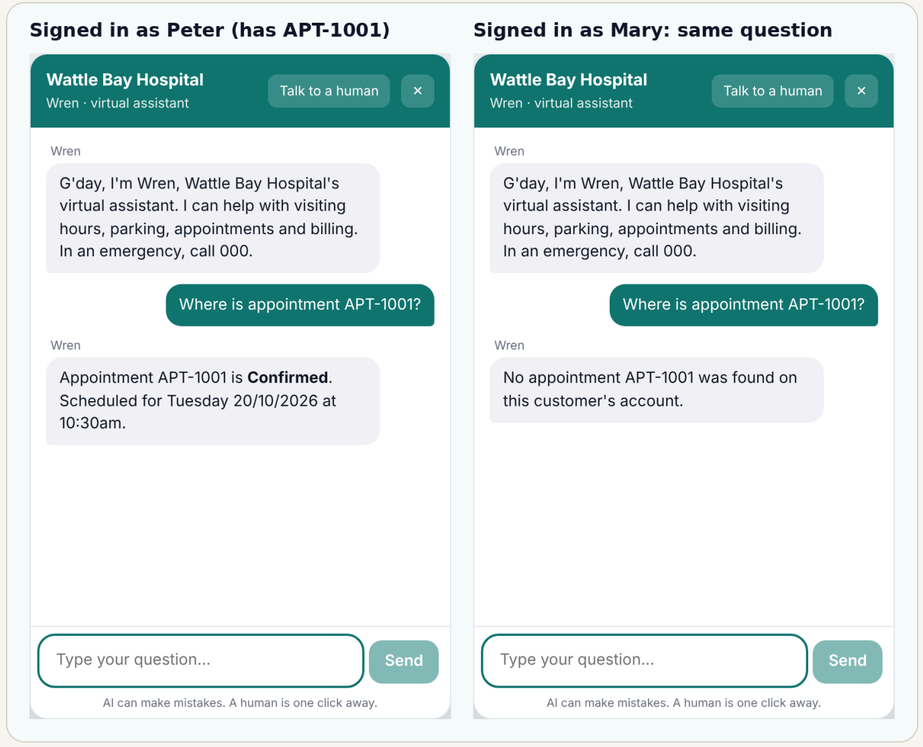
07 · AUTHORIZATION

The model can’t choose whose data it reads

```
# orchestrator: only schema-declared args reach a tool
clean = {k: v for k, v in args.items() if k in declared}

# identity comes from the token, never an argument
order = await orders.get_order(ctx.user.id, order_id)
if order and order.customer_id ≠ ctx.user.id:
    order = None      # defence in depth + alert
if order is None:     # not yours == doesn’t exist
    return {"found": False, ...}
```

- **No oracle:** “not yours” and “doesn’t exist” look identical
- **Allow-listed view:** no address or payment reaches the model
- **Audited:** every lookup logged; violations hit an alert metric



Five ways to reach a person, one of them model-free

`bot` › `waiting_human` › `with_human` › `resolved`

Model decides: calls escalate_to_human with a summary

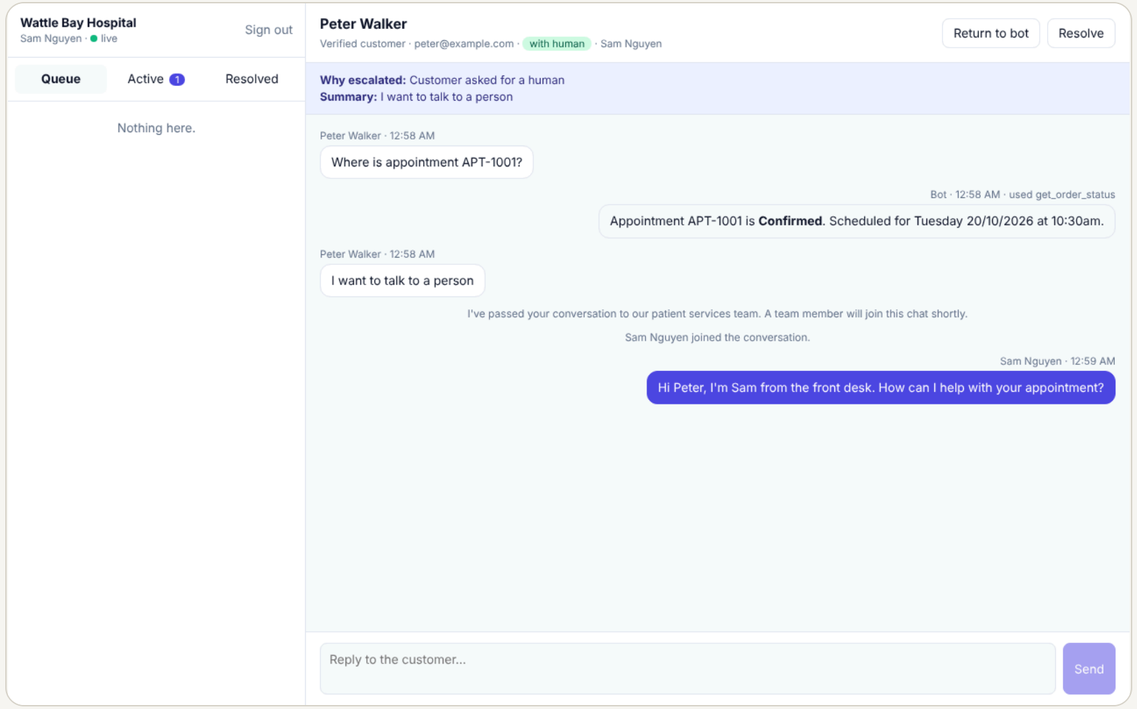
Button: “Talk to a human” in the widget

Phrase: regex safety net, never asks the model

Repeated misses: two KB misses in a row

Failure: outage, timeout, refusal or loop limit

Agents see the reason, the summary and any tickets. The bot is silent while a human owns the chat; Redis fans messages out across pods.



09 · RESILIENCE

Every dependency can fail; the customer never notices

LLM guard

Up to 64 concurrent model calls per pod, a 20 s queue timeout and a 60 s call timeout. Failures become typed errors: overload, timeout, error.

Fallback, then a human

A retryable failure moves to a fallback model, from any vendor. If that fails too, the customer gets an apology and a person, not an error.

Ticket outbox

Jira slow or down? The ticket is saved with a REQ-n reference; a worker retries with backoff (30 s up to 1 h) and an idempotency key.

Contained tool failures

A tool exception becomes an error result for the model, not a crashed chat. Unknown tools and undeclared arguments never execute.

Readiness is a set of gates, not a feeling

153
unit and integration tests, real Redis

94%
coverage, against an 88% gate

69/69
platform security cases, zero tolerance

18/18
resilience cases (outages, timeouts)

The evaluator is evaluated

Tests plant an IDOR bug, accept forged tokens, drop tenant scoping, swap in a hallucinating model and a rubber-stamp judge, and require the suites to fail.

Verdict today: NOT READY, on purpose

Real-model suites need an API key (about $8 a run), load needs a Postgres + Redis staging rerun, and 12 manual items are open.

11 · LOAD TEST

The load test found a bug no unit test did

SYMPTOM

The first ramp collapsed at about 1.6 conversations/s. p95 overhead went from 33 ms to 2.4 s.

CAUSE

Each turn kept a DB connection checked out for the whole model call, so concurrency was capped at the pool size of 15.

FIX

End the transaction before every wait on the model, Jira or the order API. Three regression tests assert zero checked-out connections.

40.5

turns/s per process, within all gates

1.25×

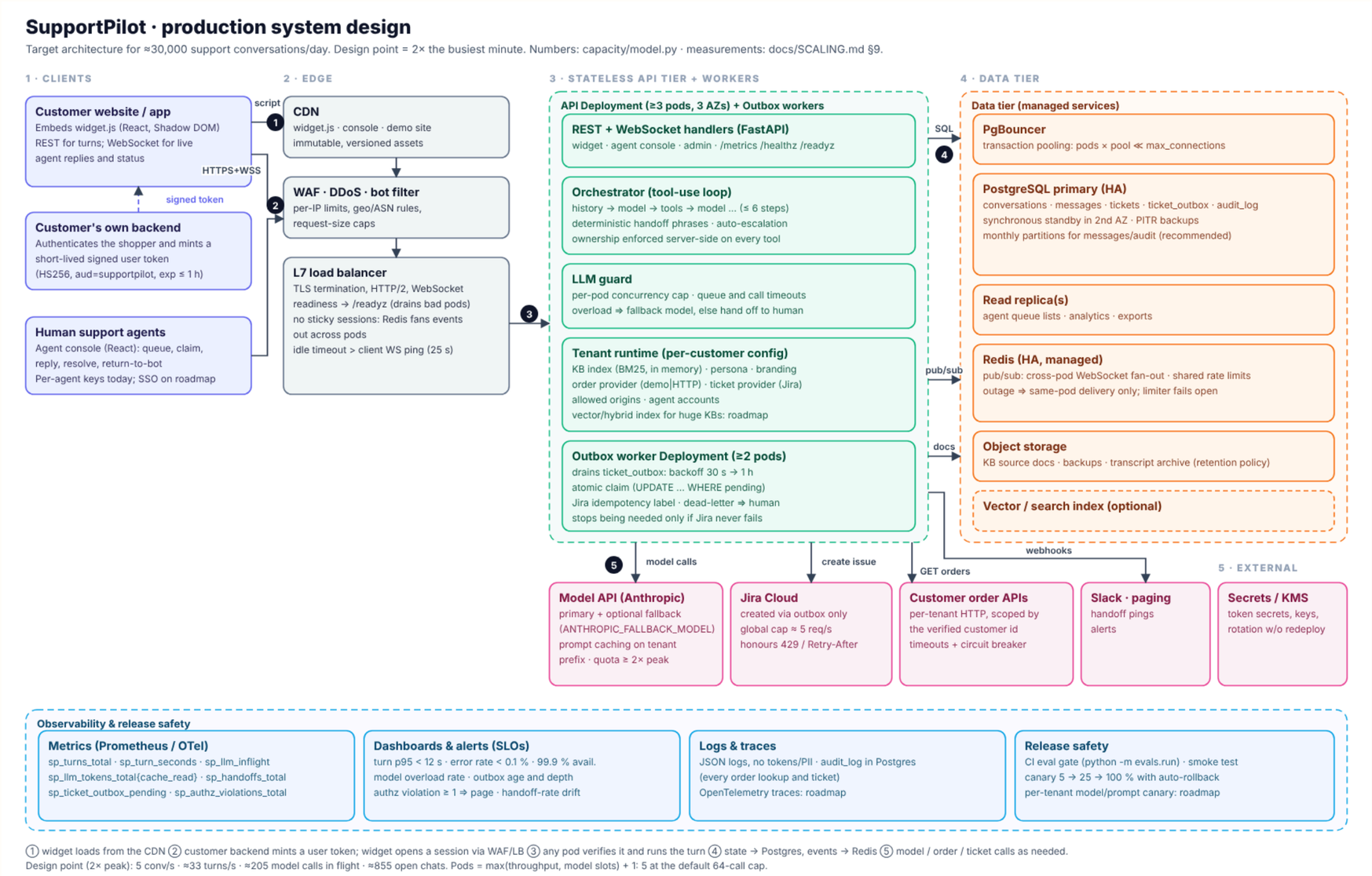
the design point (~30k conversations/day)

0 errors · p95 platform overhead 362 ms

What I’d build next, in order

Gap today	Why it matters	Next step
Not yet evaluated on a real model	No measured answer quality yet	Run the full eval suite (~$8)
Postgres and Docker untested	Only SQLite is verified	Staging run with Postgres + Redis
No schema migrations	First schema change is risky	Add Alembic before any change
Uploads land on one pod’s disk	Breaks with several replicas	Object storage, or config from git
BM25 only; .md and .txt only	Misses paraphrases and PDFs	Hybrid search behind search()
Replies aren’t streamed	Long answers feel slow	Stream tokens over the WebSocket
Agents sign in with API keys	No SSO or roles	SSO and role-based access

Where it goes at ~30,000 conversations a day



THREE THINGS TO REMEMBER

1 Identity is never the model’s decision.

2 Every failure path ends with a human.

3 Readiness is measured, not claimed.

Thank you · github.com/akhil4rajan/supportpilot-ai